

29th International Conference on Knowledge-Based and Intelligent Information & Engineering Systems (KES 2025)

Automated Generation of Cybersecurity Response Playbooks via Large Language Models

Ciprian Paduraru^a, Bogdan Dumitru^a, Alin Stefanescu^{a,b}

^aUniversity of Bucharest, Romania

^bInstitute for Logic and Data Science, Romania

Abstract

Modern cybersecurity incident response workflows remain highly reliant on manual intervention, frequently resulting in delays and inconsistencies in threat mitigation. This paper introduces an automated method that leverages compact, fine-tuned large language models (LLMs) to generate CACAO-compliant security playbooks from structured incident data, aligned with emerging cybersecurity standards. To support both model fine-tuning and empirical evaluation, we introduce a novel dataset that integrates validated real-world incidents with systematically constructed synthetic scenarios. The approach uses a JSON-based intermediate representation to facilitate the structured transformation of incident data into executable mitigation procedures. In addition, we incorporate post-processing routines and prompt optimization techniques to improve structural validity and semantic coherence. Experimental results indicate that task-adapted compact LLMs achieve performance comparable to significantly larger models. At the same time, they reduce computational requirements, enabling deployment in resource-constrained environments and integration with existing SIEM and SOAR systems.

© 2025 The Authors. Published by Elsevier B.V.

This is an open access article under the CC BY-NC-ND license (<https://creativecommons.org/licenses/by-nc-nd/4.0>)

Peer-review under responsibility of the scientific committee of the KES International.

Keywords: Cybersecurity automation; Incident response; SIEM/SOAR integration; Large language models (LLMs); CACAO playbooks

1. Introduction

Cybersecurity remains an evolving challenge as organizations face sophisticated threats that exploit vulnerabilities in interconnected digital infrastructures. Modern Security Operations Centers (SOCs) increasingly rely on automated and semi-automated tools such as Security Information and Event Management (SIEM), Endpoint Detection and Response (EDR), and Security Orchestration, Automation, and Response (SOAR) systems [1] to enable real-time detection, logging, and alerting. However, despite these advances in detection, the subsequent phases of incident response - particularly mitigation planning, playbook creation, and execution - remain mostly manual, time-consuming, and prone to inconsistency. This gap in automation hinders response efficiency and burdens analysts with repetitive tasks, especially under time pressure.

In this paper, we introduce *CyberPlaybookLLM*, a fine-tuned language model specifically designed to streamline incident analysis by automatically predicting mitigation steps and generating structured CACAO 2.0 (Collaborative

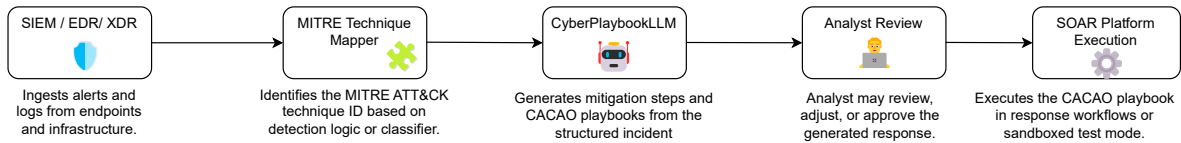


Fig. 1: Deployment scenario of CyberPlaybookLLM within existing cybersecurity tools.

Automated Course of Action Operations) playbooks [2]. CACAO 2.0 <https://docs.oasis-open.org/cacao/security-playbooks/v2.0/security-playbooks-v2.0.html> is an emerging open standard maintained by the OASIS consortium, offering a machine-readable, vendor-neutral format for encoding response actions. Its structured representation facilitates automation, interoperability across security tools, and integration into existing SOAR platforms. It is adopted by major industry players such as IBM, Splunk, and the Open Cybersecurity Alliance.

By leveraging structured supervised fine-tuning and integrating with existing cybersecurity infrastructures, CyberPlaybookLLM improves both the efficiency and effectiveness of cybersecurity incident handling workflows. In our work, we adopt the MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework as a foundational standard for labeling and contextualizing incident data. This framework provides a widely accepted and structured vocabulary for describing adversarial behaviors across multiple stages of the attack lifecycle [3]. In our system, MITRE ATT&CK functions as a static threat ontology used during dataset generation and prompt construction; we do not perform real-time ontology inference or runtime reasoning over external knowledge sources.

Figure 1 illustrates a realistic deployment scenario demonstrating how CyberPlaybookLLM integrates into typical cybersecurity operations. Raw logs and alerts are initially collected by detection platforms (e.g., SIEM, EDR, or XDR), which then optionally identify relevant MITRE ATT&CK [3] <https://attack.mitre.org> techniques using lightweight classifiers [1]. These structured inputs (technique identifiers, descriptions, and summaries) are subsequently processed by CyberPlaybookLLM, which outputs both mitigation steps and structured CACAO-compliant playbooks. Analysts may optionally review and adjust the suggested playbooks before deploying them through a SOAR platform, facilitating efficient incident response automation in real-world cybersecurity environments.

Although prior work (Section 2) has demonstrated the potential of LLMs in parsing security data, classifying alerts, and interactively supporting analysts, there are still gaps in structured playbook synthesis, real-time integration with CACAO standards, and seamless mapping to threat frameworks such as MITRE ATT&CK. Our approach introduces a novel LLM-based pipeline that fills these gaps by enabling dynamic generation of CACAO-compliant playbooks directly from unstructured incident data and by incorporating structured threat labeling via the MITRE ATT&CK framework, which guides dataset construction and aligns generated playbooks with established response taxonomies.

We summarize our contributions as follows: (a) We introduce the first curated CACAO-aligned dataset that blends real-world and synthetic incident scenarios. To support LLM inference, a structured JSON-based intermediate format is defined, capturing key elements such as attack tactics, indicators, and affected assets. (b) We propose the first end-to-end approach using language models to generate both high-level mitigation strategies and executable CACAO playbooks directly from structured incident descriptions. (c) We ensure practical usability by fine-tuning a compact model (LLaMA 3.1–8B [4]) that approaches the performance of larger LLMs while significantly reducing resource requirements. Cost efficiency is further enhanced through prompt engineering, an optimized JSON middleware interface, and lightweight post-processing of LLM outputs. (d) We provide a deployable system compatible with existing SIEM/SOAR platforms. All code, models, and datasets are publicly released at: <https://github.com/unibuc-cs/CyberPlaybookLLM>.

2. Related Work

LLMs in Cybersecurity Operations. Recent research highlights the growing impact of LLMs in automating and enhancing cybersecurity workflows. Works such as [5] and [6] offer comprehensive surveys on the integration of LLMs into cybersecurity applications, demonstrating capabilities ranging from log parsing to automated incident handling. Notably, [7] explores how GPT models can structure unstructured reports, accelerating incident triage and reducing human workload. Similarly, [8] and [9] emphasize the ability of LLMs to assist with log analysis, anomaly detection, and dynamic response generation. However, concerns around reliability are discussed in [10], where hallucination and

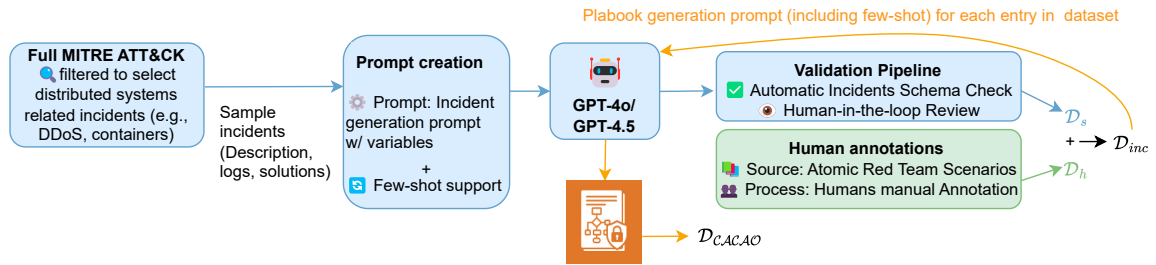


Fig. 2: Pipeline for generating structured cybersecurity datasets.

factual correctness remain key challenges. Methods to enhance structured output generation, such as those proposed in [11], address the need for validation layers when deploying LLMs in critical domains.

Security Standards and Playbook Automation. The CACAO standard [2] provides a structured and interoperable format for security playbooks but currently lacks support for automation in authoring and adaptation. Manual playbook development remains time-consuming and error-prone, leading to inconsistency and inefficiency, as highlighted by [12]. The work in [2] introduces a knowledge management approach to improve the reuse and collaborative maintenance of CACAO playbooks. Integrating LLMs into this context presents a promising direction for automating and optimizing playbook generation workflows.

Log Analysis. Automated techniques for mapping system logs to ATT&CK techniques are addressed in [13], which uses the Atomic Red Team [13] dataset to infer threat behavior. Similarly, the work in [3] outlines the design rationale for MITRE ATT&CK for Industrial Control System (ICS) environments. The fusion of deep learning and ontology for extracting MITRE tactics from unstructured reports, as in [1], provides a semantic layer that complements purely syntactic log-matching approaches.

Adaptive and Explainable AI for SIEM Systems. The volume and complexity of alerts in modern SIEM systems are addressed by [14], which proposes a zero-shot learning approach enhanced with explainable AI. Their framework classifies alerts, including previously unseen threats, offering a foundation for scalable alert triage.

LLM Fine-tuning and Optimization. Techniques such as parameter-efficient tuning on quantized models, e.g., QLoRA [15], make LLMs accessible for security-specific adaptations. Broader surveys like [16] and [17] explore domain adaptation, model scaling, and synergistic multi-task tuning. Predictive frameworks such as [18] aim to forecast performance before fine-tuning at scale, saving computational resources.

Prior Work on Cybersecurity Assistants. Our previous systems, CyberGuardian [19] and CyberGuardian 2 [20], introduced LLM-based assistants capable of helping cybersecurity analysts in distributed network environments. Although effective in extracting relevant information and suggesting mitigations, these systems did not incorporate playbook synthesis or CACAO integration. The current work builds upon this foundation by introducing a modular capability for automated playbook generation, extending the assistant’s functionality toward response orchestration and standard-aligned automation.

3. Methodology for Dataset Creation

Figure 2 illustrates the complete workflow used to construct two structured datasets for incidents and CACAO playbook evaluation. The first is the incident dataset $\mathcal{D}_{inc}$, composed of a synthetic portion $\mathcal{D}_s$ and a human-annotated portion $\mathcal{D}_h$. The pipeline begins by filtering relevant MITRE ATT&CK [3] techniques, followed by two parallel generation streams. $\mathcal{D}_s$ is created via few-shot-enabled prompting of LLMs (GPT-4o and GPT-4.5-preview), with all outputs undergoing schema-based and manual validation. In parallel, $\mathcal{D}_h$ is derived from Atomic Red Team [13] scenarios, manually annotated to ensure expert-labeled ground truth.

Once validated, each entry in $\mathcal{D}_{inc} = \mathcal{D}_s \cup \mathcal{D}_h$ is transformed into a CACAO-compliant playbook using a dedicated prompt-driven generation process. This produces a second dataset, $\mathcal{D}_{CACAO}$, consisting of structured playbooks.

To support experiments in automated cybersecurity playbook generation, we constructed a structured dataset aligned with the MITRE ATT&CK framework, focusing specifically on techniques relevant to distributed systems. The process began with filtering the full list of attack techniques using a keyword-based strategy to retain those most

```

1 You are a cybersecurity simulation assistant. Generate a JSON object representing a cybersecurity incident aligned with a MITRE ATT&CK technique
  described at: https://attack.mitre.org/techniques/{technique_id}/
2
3 Required fields:
4 - incident_id (UUID)
5 - technique_id (e.g., T1059)
6 - technique_desc (short summary)
7 - incident_description (2-sentence narrative)
8 - attack_logs: 3 entries with timestamp (ISO), host, action, details
9 - ground_truth_mitigations: 3-6 objects with step, uuid, agent, command; optionally: condition, loop, variables
10
11 Encourage variety in structure:
12 - Some steps may include conditionals (if/else), loops (repeat until clean), or run in parallel.
13 - Use variable linkages if needed.
14
15 Return valid JSON only for:
16 Target MITRE Technique:
17 {technique_id} - {technique_desc}

```

Listing 1: Compacted version of the synthetic incident generation template prompt, including two template variables representing the attack technique ID and description. The prompt instructs the LLM to reference the official MITRE ATT&CK URL, allowing tool-based retrieval of up-to-date threat intelligence during generation.

relevant to distributed environments, which represent the focus of the evaluation in this use case. Keywords included "distributed denial of service (DDoS)," "cluster compromise," "container escape," "microservice exploit," and "API gateway attacks." This filtering resulted in a curated list of 161 techniques which formed the foundation of the dataset.

Next, we extracted 161 real-world adversarial scenarios, one per selected technique, from the Atomic Red Team repository [21]. This ensured practical relevance and provided grounded examples of TTPs (Tactics, Techniques, and Procedures) observed in real environments. To expand the dataset, 1,211 synthetic incident entries were generated, uniformly distributed across the same 161 techniques. Two high-performance language models, GPT-4o and GPT-4.5-preview [22], were used for this task. GPT-4.5-preview was used to generate 300 examples, while the remaining 911 examples were produced using GPT-4o, which offered a favorable cost-to-quality ratio while still maintaining good performance in terms of structural coherence and accuracy. We selected GPT-based models (GPT-4o and GPT-4.5-preview) for dataset generation due to their strong few-shot performance and low prompt engineering overhead. These models consistently produced high-structure, semantically coherent outputs with minimal tuning. In contrast, LLaMA 3.1–8B was reserved for downstream fine-tuning of CyberPlaybookLLM, as it required more careful supervision during generation and did not offer practical advantages for the dataset construction stage.

To ensure the quality of synthetic incident data, we implemented a two-stage validation pipeline. The first stage involved automatic validation scripts that checked for schema compliance, field completeness, and internal consistency. In the second stage, remaining entries were manually reviewed by expert annotators to identify subtle logical errors or under-specified fields. This human-in-the-loop step ensured that all retained incidents exhibited coherent threat narratives and realistic log entries. The overall rejection rates for each stage are reported in Table 3. Approximately 15% of the initial entries failed automatic validation, and an additional 23% were discarded during manual review. In total, around 1,865 initial entries were produced to yield the final validated set of 1,211 synthetic incidents.

Prompt engineering played an important role in obtaining structured and meaningful outputs. Initial model generations were often generic or disconnected from the input context. To address this, the prompts were incrementally refined with strict instructions: requiring references to hosts and logs, enforcing consistent and realistic timestamp formats, specifying the number of actions, and guiding format adherence. Additionally, few-shot examples drawn from the validated corpus were included to guide the model. The structure of the prompt is summarized in Listing 1, and a representative output entry is shown in Listing 4.

3.1. Generating playbooks from incident entries

Structured security incidents are translated into CACAO playbooks using prompt-guided language model generation, which instructs the model to: (a) Parse the incident logs and mitigation steps. (b) Create a workflow with a start step, one sequential action per mitigation, and a final step. (c) Reference hostnames, filenames, and identifiers directly from the incident context. (d) Populate required CACAO metadata fields, including type, spec_version, id, modified, created_by, workflow_start, and workflow, which defines the graph node structure.

```

1 You are a cybersecurity automation assistant. Generate a CACAO playbook from a structured incident JSON. Include:
2 - One 'start' node
3 - One action per mitigation, defining for each: id, agent, commands (e.g., bash commands or tools invocation).
4 - Use advanced nodes: conditionals (if/else), parallel steps, loops (repeat-until), variable links (e.g., scan_result -> decision).
5
6 Each step type must use one of: start, action, if-condition, while-condition, end. For each action provide an agent id.
7
8 Examples:
9 {few_shot_examples}
10
11 Input incident:
12 {''json
13 {incident_json_str}

```

Listing 2: Compacted prompt to convert an incident into a CACAO-compliant playbook. The template variable `few_shot_section` is used to insert reference examples that guide the generation process. The incident data and corresponding mitigation steps are provided via the variable `incident_json_str`.

The skeleton of the generation prompt used is shown in Listing 2. An example output playbook is visualized in Figure 3. The prompt structure was iteratively refined to ensure that the generated playbooks are both syntactically valid and semantically grounded in the source incident data.

3.2. Few-shot prompting for playbook generation

To improve both structural correctness and semantic fidelity of generated CACAO playbooks, we extended the base prompt with few-shot examples. These examples were sourced from previously validated playbooks (either manually authored or generated in earlier successful sessions) and were selected to reflect key control-flow constructs in the target syntax. Their inclusion provided the language model with grounded examples of JSON formatting, node linkage, Bash command structure, and variable handling.

To ensure behavioral coverage, three representative few-shot playbooks were selected, each exemplifying a distinct type of workflow behavior:

- Linear playbook: a simple sequential set of mitigation actions with a single execution path.
- Conditional and iterative playbook: includes at least one decision node (if-else) and a loop condition based on a variable (e.g., `repeat until scan passes`).
- Parallel playbook: multiple mitigation steps are executed concurrently, branching from a common parent node.

Few-shot entries were embedded in the prompt using Markdown-style JSON blocks to ensure consistent formatting. These were inserted via the template variable `{few_shot_examples}`, as shown on Listing 2 line 9.

Despite prompt optimizations, language model outputs continued to produce structural and semantic inconsistencies in a non-negligible number of cases. To address this, a dedicated post-processing pipeline was introduced, incorporating rule-based heuristics to automatically correct formatting and logic errors in the generated playbooks. This repair mechanism proved essential for producing structurally valid and executable artifacts, as evidenced by the improvements shown in Table 4.

The key post-processing steps are as follows:

- UUID repair: Invalid or improperly formatted UUIDs are regenerated, with a mapping stored to preserve consistency across workflow references.
- Entity normalization: Improper or missing declarations of named entities (e.g., agents, clusters) are standardized to ensure valid references throughout the playbook.
- ID validation: The playbook identifier and all workflow node IDs are examined for consistency and regenerated if malformed.
- Workflow type inference: When a node's type (e.g., `action`, `decision`, `loop`) is incorrectly specified or omitted, the system infers the appropriate classification based on contextual cues such as the node's name, description, and structural position within the workflow.
- Command synthesis (e.g., bash calls, external tools invocation): Missing or unexecutable commands are substituted with minimal Bash-style statements that reflect the intended action or provide guidance to the operator.

- Condition resolution: Variable names used in loops and decision branches are cross-checked against the full playbook to ensure they are consistently defined and referenced.

This two-tiered approach, i.e., prompt design with few-shot support followed by heuristic post-processing, proved effective in generating CACAO compliant playbooks that were structurally valid, semantically grounded, and executable within downstream pipelines (Table 4).

4. Fine-Tuning CyberPlaybookLLM

For structured cybersecurity reasoning, a LLaMA 3.1-8B model is fine-tuned using the incident and playbook datasets, $\mathcal{D}_{\text{inc}}$ and $\mathcal{D}_{\text{CACAO}}$, respectively. The resulting model, *CyberPlaybookLLM*, was trained to perform both mitigation prediction and playbook generation based on semantically enriched incident representations.

The task is initially decomposed into two functional stages: predicting mitigation steps from structured incidents and constructing executable playbooks based on those predictions. This separation enables focused evaluation of each sub-task and provides clearer insights into model behavior. For deployment, however, these steps are integrated into a single training pipeline, where the model is conditioned on an incident description and trained to generate both the mitigation plan and the corresponding playbook in a single pass (see Listing 2).

Stage 1 – Mitigation Prediction. The first phase focuses on learning to infer mitigation steps from structured cybersecurity incidents. Inputs include the MITRE technique ID, a concise incident summary, log snippets, and three few-shot examples. The target output is the `ground_truth_mitigations` field, consisting of structured response actions. Supervised fine-tuning (SFT) [16] is applied to $\mathcal{D}_{\text{inc}}$, with task separators guiding the model’s attention and improving alignment between incident context and mitigation logic.

Stage 2 – Playbook Construction. In the second phase, the model learns to transform incidents and their associated mitigation plans into structured executable playbooks. Full JSON logs were initially included as input but proved inefficient due to verbosity and redundancy. As a result, a compact input format was adopted, consisting of MITRE technique metadata, a high-level narrative, and a list of predicted or ground-truth mitigations.

Unified Training Strategy. For deployment efficiency, the two tasks are unified into a single training pipeline. *CyberPlaybookLLM* is trained to receive an incident summary and produce both the mitigation steps and the corresponding structured playbook in one generation pass. This approach preserves the interpretability of intermediate reasoning steps while simplifying the model architecture and reducing inference cost.

Input Optimization. The unified setup benefits from carefully optimized inputs. Rather than relying on raw logs, the model receives structured summaries that include technique metadata, a narrative of the attack, and the mitigation sequence. This compact format aligns with the training distribution, improves generation stability, and significantly reduces latency. Raw logs may still be introduced during training for robustness, but are excluded at inference time. A representative example appears in Listing 3, Line 5.

5. Evaluation

The goal of this evaluation is to assess model performance, cost-efficiency, and the practicality of deploying our system in real-world cybersecurity operations. A structured analysis is conducted covering dataset generation, prompting strategies, and end-to-end CACAO playbook synthesis. Specifically, we examine the reliability of LLMs in generating realistic incident and playbook data, the effect of few-shot prompting and post-processing on output validity, and the ability of the fine-tuned compact model, *CyberPlaybookLLM*, to perform comparably to larger models.

5.1. Dataset creation process

We evaluate the performance, validation and post-processing outcomes, and estimated cost of generating two datasets using large language models: the incident dataset $\mathcal{D}_{\text{inc}}$ and the playbook dataset $\mathcal{D}_{\text{CACAO}}$. Additionally, we include the cost and labor effort associated with manual annotation of ground truth incidents. Results are summarized in Table 1. A total of 1,211 synthetic incidents were validated in $\mathcal{D}_{\text{inc}}$, alongside 161 human-annotated cases curated from Atomic Red Team scenarios. The synthetic entries were generated using GPT-4o and GPT-4.5-preview. As part of our two-stage validation pipeline (see Section 3), 236 samples were rejected—161 during automatic schema checks and 75 during manual expert review. GPT-4.5-preview demonstrated higher structural accuracy, with significantly fewer automatic rejections. For $\mathcal{D}_{\text{CACAO}}$, a total of 1,372 playbooks were generated from validated incident entries. GPT-4o was used for 200 of these, while the remainder were produced using GPT-4o-mini due to cost-efficiency. Each playbook averaged between 2,000 and 3,000 tokens, contributing significantly to overall generation cost.

```

1  ### Input (Structured Incident + Mitigations):
2  {
3    "technique_id": "T1059",
4    "technique_desc": "Command and Scripting Interpreter",
5    "incident_summary": "Malicious script execution on host-22 with escalation on host-37...",
6    "mitigations": [
7      { "step": "Kill process", "agent": "org--abc", "command": "pkill -9 ..."},
8      { "step": "Revoke access", "agent": "org--xyz", "command": "usermod -L ..."},
9      ...
10   ]
11 }
12
13 ### Output (CACAO Playbook):
14 {
15   "type": "playbook",
16   "spec_version": "cacao-2.0",
17   "workflow_start": "start--...",
18   "workflow": {
19     "start--...": { "type": "start", "on_completion": "action--..." },
20     "action--...": {
21       "type": "action",
22       "name": "Kill process",
23       "agent": "org--abc",
24       "commands": [{ "type": "bash", "command": "pkill -9 ..." } ],
25       "on_completion": "action--..."
26     },
27     ...
28   }
29 }

```

Listing 3: Training example used for end-to-end fine-tuning of CyberPlaybookLLM. The input contains an incident summary and mitigation steps; the output is a CACAO-compliant playbook JSON.

Table 1: Performance and estimated cost of generating the incident dataset $\mathcal{D}_{inc}$ and the CACAO playbook dataset $\mathcal{D}_{CACAO}$.

Model / Source	Validated Entries	Rejected Samples (Auto / Manual)	Invalidation Rate (%)	Cost Estimate (Total + Per Entry)
<i>Incident Dataset $\mathcal{D}_{inc}$</i>				
GPT-4o	911	145 / 40	16.9	\$36.45 (\$0.034)
GPT-4.5-preview	300	16 / 35	14.5	\$25.50 (\$0.068)
Synthetic Total	1,211	161 / 75	16.3	\$61.95
Human-Annotated (Red team dataset [13])	161	0	0	54 person-hours (8 annotators)
<i>Playbook Dataset $\mathcal{D}_{CACAO}$</i>				
GPT-4o	200	–	–	\$4.50 (\$0.0225)
GPT-4o-mini	1,172	–	–	\$2.64 (\$0.00225)
Total Playbook Cost	1,372	–	–	\$7.14

Table 2: Impact of few-shot prompting on playbook correctness during synthetic dataset generation (averaged over multiple runs). Correctness is defined as the percentage of playbooks passing both structural schema validation and semantic alignment with the intended mitigation steps. Only valid playbooks were retained.

Model	Without Few-Shot (%)	With Few-Shot (%)	Improvement (%)
GPT-4o	85.2	94.8	+9.6
GPT-4o-mini	43.5	71.2	+27.7

The impact of few-shot prompting was evaluated by comparing the correctness of playbooks generated *with* and *without* few-shot examples using the two models in the study. A playbook was considered correct if it satisfied both structural schema validation and semantic alignment with the intended mitigation steps from the source incident. Table 2 summarizes the improvements observed when few-shot prompting was applied.

The results indicate that, while GPT-4o already achieves strong baseline performance, few-shot prompting provides a measurable improvement in both structural reliability and semantic grounding, particularly for GPT-4o-mini. Improvements are most evident in the generation of advanced workflow constructs such as loops, conditionals, and parallel execution patterns, which are more reliably produced when the model is guided by well-formed examples. Overall, these findings suggest a path toward cost efficiency, as comparable performance may be achievable with smaller models when supported by effective prompt design.

5.2. Evaluation of structured playbook generation

CyberPlaybookLLM is evaluated across two tightly coupled generation tasks: (1) predicting mitigation steps from incident-level inputs, and (2) transforming those mitigations into a valid CACAO-compliant playbook. The evaluation was conducted over a held-out set of 200 structured incidents from $\mathcal{D}_{inc}$, with corresponding playbooks in $\mathcal{D}_{CACAO}$.

```

1 {
2   "technique_id_...": {
3     "incident_id": 'f25e5d1b-...',
4     "technique_id": 'T1059',
5     "technique_desc": 'Command and Scripting Interpreter',
6     "incident_description": 'Malicious script..',
7     "attack_logs": [
8       {"timestamp": '...', "host": 'host-22', "action": 'Execution', "details": 'Suspicious script..'},
9       {"timestamp": '...', "host": 'host-37', "action": 'Priv Esc', "details": 'Admin access..'},
10      {"timestamp": '...', "host": 'host-22', "action": 'Persistence', "details": 'Backdoor..'}
11    ],
12    "ground_truth_mitigations": [
13      {"step": 'Kill process..', "uuid": '...', "agent": 'org--abc', "command": 'pkill -9..', "condition": 'if running'},
14      {"step": 'Revoke access..', "uuid": '...', "agent": 'org--xyz', "command": 'usermod -L..', "variables": {"user": 'compromised_user'}},
15      {"step": 'Scan systems..', "uuid": '...', "agent": 'org--abc', "command": 'clamscan -r..', "loop": 'until clean', "condition": 'if virus', "
16        variables": {"scan_result": 'virus_found'}},
17      {"step": 'Update EPP..', "uuid": '...', "agent": 'org--xyz', "command": 'update-endpoint..', "variables": {"hosts": 'host-22,host-37'}},
18      {"step": 'Reset accounts..', "uuid": '...', "agent": 'org--abc', "command": 'passwd --expire..', "parallelizable": true}
19    ]
20  }
21 \

```

Listing 4: Synthetic incident generated and aligned with MITRE ATT&CK T1059 (Command and Scripting Interpreter), showing logs and conditional/loop mitigations. The incident corresponds to the playbook in Figure 3

Table 3: Performance of CyberPlaybookLLM across mitigation prediction and CACAO playbook generation (200-sample validation set). Note that the evaluation of Schema Validity metric includes the post-processing improvements.

Metric	Score (%)	Token Count (avg)
Mitigation Precision / Recall	84.3 / 79.6	–
Schema Validity Rate	96.8	–
Node Alignment Score	91.2	–
Execution Path Completeness	92.5	–

used as reference targets.

Implementation Setup. The model was fine-tuned using supervised learning with Hugging Face’s transformers and trl libraries, using QLoRA [15] for memory-efficient training on a single H100 80GB GPU. Training used a batch size of 32, a learning rate of 2e-5, and a maximum sequence length of 4,096 tokens. Each input-output pair was organized using a task-prefixed template that separates the incident summary, predicted mitigations, and the corresponding CACAO playbook.

Metrics. Evaluation was conducted across two generation stages: mitigation prediction and playbook construction. For the mitigation stage, performance was measured using precision and recall, capturing how accurately the model predicted relevant steps relative to ground truth annotations. For the playbook generation stage, evaluation focused on structural and semantic correctness. The schema validity rate captures the percentage of outputs conforming to the CACAO specification, as verified by automated schema validation. The node alignment score reflects how accurately the predicted mitigation steps were mapped into the appropriate node types (e.g., action, loop, decision). Additionally, execution path completeness measures whether all workflow nodes form a connected and valid graph from the designated start node to a terminating end node. The results of our evaluation are summarized in Table 3.

Observations and Insights. The evaluation shows that CyberPlaybookLLM performs reliably across both prediction stages. The mitigation predictor achieves high precision (84.3%) and recall (79.6%) when benchmarked against reference annotations. Generated CACAO playbooks achieved a 96.8% schema validity rate, and over 91% of predicted mitigation steps were correctly translated into structured workflow nodes. Notably, nearly all workflows were logically complete, with valid start–end paths.

Input formatting choices also contributed significantly to model efficiency. By replacing verbose attack logs with high-level incident summaries and structured mitigation plans, the average input length was reduced by 47.3%, improving model latency and reducing cost per query without compromising structure or fidelity. Remaining errors were primarily attributed to incorrect variable propagation or unreachable branches, which could be mitigated in future work via schema-aware decoding or RLHF.

Inference and deployment. Inference speed is an important factor for practical deployment. On an NVIDIA RTX 4090 GPU (24GB VRAM), CyberPlaybookLLM processes inputs consisting of 1,000–2,000 tokens (e.g., summarized logs and associated attack techniques) and generates 2,000–3,000 output tokens (representing the mitigation plan and

Table 4: Effect of post-processing on CACAO playbook validity across models. All 1,372 structured incidents in dataset $\mathcal{D}_{inc}$ were converted into playbooks. The table reports schema validity rates before and after applying a post-processing script, which includes few-shot prompting and structural corrections.

Model	Valid Before (%)	Valid After (%)	Gain (%)
GPT-4o	94.5	100.0	+5.5
GPT-4o-mini	71.2	98.6	+27.4
LLaMA 3.1 8B (Vanilla)	28.7	34.1	+5.4
CyberPlaybookLLM (ours)	60.3	96.8	+36.5

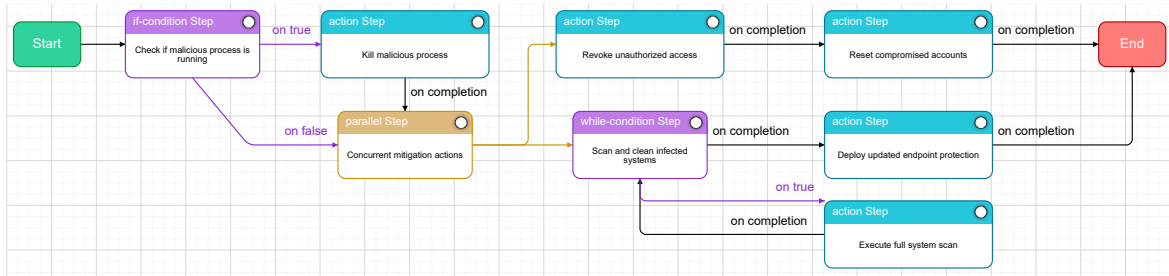


Fig. 3: Visualization of a CACAO playbook generated by CyberPlaybookLLM using the official authoring tool available at <https://github.com/opencybersecurityalliance/cacao-roaster>. The playbook describes an incident response to a phishing email delivering a malicious attachment, which leads to ransomware deployment. It includes mitigations for techniques T1566.001 (Phishing: Attachment), T1203 (Client Exploitation), and T1486 (Data Encryption), covering filtering, macro blocking, isolation, anti-malware scans, and backup restoration. This corresponds to the incident shown in Listing 4.

CACAO playbook) in approximately 3.2 to 4.1 seconds. This level of latency supports integration into automated security pipelines that require timely response execution, on end-user hardware capabilities.

5.3. Impact of post-processing on playbook validity

To assess the effectiveness of the post-processing heuristics, CACAO playbooks were evaluated across the structured incident dataset $\mathcal{D}$, comprising 1,372 entries. Four language models were considered: GPT-4o, GPT-4o-mini, LLaMA 3.1 8B (vanilla), and the fine-tuned variant CyberPlaybookLLM. Sample allocation across models was guided by performance and cost-efficiency considerations, with GPT-4o generating 200 entries and GPT-4o-mini used for the remaining majority. Both LLaMA-based models were evaluated (using local hardware) on the full dataset for comparative analysis.

Each playbook was validated against the CACAO JSON schema before and after applying the post-processing script. As shown in Table 4, GPT-4o achieved high correctness (94.5%) pre-processing, reaching 100% post-processing. GPT-4o-mini saw substantial improvement from 71.2% to 98.6%. The LLaMA 3.1 8B vanilla model performed poorly, with only a modest increase from 28.7% to 34.1% after post-processing.

5.4. Operational Considerations: Safety, Prompting, and Failure Handling

We emphasize that CyberPlaybookLLM is explicitly designed for safe, analyst-mediated operation. All generated mitigation steps and CACAO playbooks require review and explicit approval by a human analyst before execution, ensuring that no unsupervised actions are performed. Rather than functioning as an autonomous agent, the system serves as a decision-support tool—accelerating incident triage and response planning while preserving human oversight and control.

In addition, while our prompt design demonstrates strong performance, we acknowledge limitations in generalization across LLM architectures, attack types, and operational domains. Prompt robustness remains an open challenge, particularly under distributional shifts or adversarial variation. The most common generation failures observed include malformed conditional branches, misaligned variable references, and disconnected workflow nodes. These issues are mitigated through a post-processing pipeline that applies rule-based structural repairs, improving both validity and executable conformity to the CACAO schema, as summarized in Table 4.

6. Conclusion and future work

This work presents a novel approach to automating cybersecurity incident response through the generation of CACAO-compliant playbooks using fine-tuned compact language models. We introduced a curated dataset of structured incidents and an intermediate JSON format optimized for LLM-based generation. Our evaluation demonstrates that smaller models, when fine-tuned appropriately, can efficiently produce actionable mitigation strategies that align with standard response frameworks. These results highlight the feasibility of deploying such systems within SIEM/SOAR environments, particularly when combined with human-in-the-loop review to ensure operational safety. Planned deployment efforts include integration into an EU Horizon project DYNABIC <https://dynabic.eu> involving industrial use cases, as well as experimental validation in a university-level SOAR sandbox. Future work will focus on multilingual support, real-time processing of streaming incident data, and enhancements to robustness across diverse attack techniques and model architectures.

Acknowledgements This research was supported by the projects “Romanian Hub for Artificial Intelligence - HRIA”, Smart Growth, Digitization and Financial Instruments Program, 2021-2027, MySMIS no. 334906 and European Union’s Horizon Europe research and innovation programme under grant agreement no. 101070455, project DYNABIC.

References

- [1] Y.-T. Huang, et al., MITREtrieval: Retrieving MITRE Techniques From Unstructured Threat Reports by Fusion of Deep Learning and Ontology, *IEEE Transactions on Network and Service Management* 21 (4) (2024) 4871–4887.
- [2] O. Tsirakis, et al., Operationalizing Cybersecurity Knowledge: Design, Implementation & Evaluation of a Knowledge Management System for CACAO Playbooks, available at: <https://arxiv.org/abs/2503.05206> (2025).
- [3] O. Alexander, M. Belisle, J. Steele, MITRE ATT&CK for industrial control systems: Design and philosophy, The MITRE Corporation (2020).
- [4] H. Touvron, et al., LLaMA: Open and Efficient Foundation Language Models, available at: <https://arxiv.org/abs/2302.13971> (2023).
- [5] J. Zhang, et al., When LLMs meet cybersecurity: A systematic literature review, *Cybersecurity* 8 (1) (2025) 1–41.
- [6] M. A. Ferrag, et al., Generative AI in Cybersecurity: A Comprehensive Review of LLM Applications and Vulnerabilities, available at: <https://arxiv.org/abs/2405.12750> (2025).
- [7] Z. Wang, Li, et al., Large Language Models Can Provide Accurate and Interpretable Incident Triage, in: 2024 IEEE 35th International Symposium on Software Reliability Engineering (ISSRE), IEEE, 2024, pp. 523–534.
- [8] D. Nyale, S. Angolo, A survey of artificial intelligence in cyber security, *International Journal of Computer Applications Technology and Research* (2022) 474–477.
- [9] T. Ahmed, S. GHOSH, C. Bansal, T. Zimmermann, X. Zhang, S. Rajmohan, Recommending root-cause and mitigation steps for cloud incidents using large language models, in: ICSE 2023, 2023.
- [10] X. Huang, W. Ruan, W. Huang, et al., A survey of safety and trustworthiness of large language models through the lens of verification and validation, *Artificial Intelligence Review* 57 (175) (2024).
- [11] A. M. Hosseini, W. Kastner, T. Sauter, Leveraging LLMs and Knowledge Graphs to Design Secure Automation Systems, *IEEE Open Journal of the Industrial Electronics Society* 6 (2025) 380–395.
- [12] A. Kougiumtzidou, A. Papoutsis, D. Kavallieros, T. Mavropoulos, T. Tsikrika, S. Vrochidis, I. Kompatsiaris, An End-to-End Framework for Cybersecurity Taxonomy and Ontology Generation and Updating, in: 2024 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE, 2024, pp. 247–254.
- [13] M. Okuma, K. Watarai, S. Okada, T. Mitsunaga, Automated Mapping Method for Sysmon Logs to ATT&CK Techniques by Leveraging Atomic Red Team, in: 2023 6th Int. Conf. on Signal Processing and Information Security (ICSPIS’23), IEEE, 2023, pp. 104–109.
- [14] D. Rao, S. Mane, Zero-shot learning approach to adaptive Cybersecurity using Explainable AI, available at: <https://arxiv.org/abs/2106.14647> (2021).
- [15] T. Dettmers, A. Pagnoni, A. Holtzman, L. Zettlemoyer, QLoRA: Efficient Finetuning of Quantized LLMs (2023). [arXiv:2305.14314](https://arxiv.org/abs/2305.14314).
- [16] V. B. Parthasarathy, A. Zafar, A. Khan, A. Shahid, The ultimate guide to fine-tuning LLMs from basics to breakthroughs: An exhaustive review of technologies, research, best practices, applied research challenges and opportunities, *arXiv preprint arXiv:2408.13296* (2024).
- [17] W. Lu, R. K. Luu, M. J. Buehler, Fine-tuning large language models for domain adaptation: Exploration of training strategies, scaling, model merging and synergistic capabilities, *npj Computational Materials* 11 (1) (2025) 84.
- [18] T. Kuramoto, J. Suzuki, Predicting Fine-tuned Performance on Larger Datasets Before Creating Them, in: Proceedings of the 31st International Conference on Computational Linguistics: Industry Track, 2025, pp. 204–212.
- [19] C. Paduraru, C. Patilea, A. Stefanescu, CyberGuardian: An Interactive Assistant for Cybersecurity Specialists Using Large Language Models, in: Proc. of the 19th Int. Conf. on Software Technologies (ICSOFT’24), 2024, pp. 8–10.
- [20] C. Paduraru, C. Patilea, A. Stefanescu, CyberGuardian 2: Integrating LLMs and Agentic AI Assistants for Securing Distributed Networks, in: Proc. of the 20th Int. Conf. on Evaluation of Novel Approaches to Software Engineering (ENASE’25), SciTePress, 2025, pp. 660–667.
- [21] R. Canary, Atomic Red Team: Open-source attack emulation, available at: <https://github.com/redcanaryco/atomic-red-team> (2024).
- [22] OpenAI, et al., GPT-4 Technical Report, available at: <https://arxiv.org/abs/2303.08774> (2024).